ACP-Fragenkatalog

> Übersetzung der englischen Fassung (`assessment/assessment-questionnaire.md`). Bei Abweichungen gilt die englische Fassung.

Dieser Fragenkatalog unterstützt Assessoren und Organisationen bei der Durchführung eines **Active Cyber Program (ACP) Assessments** oder einer Selbstbewertung.

Jede Zeile entspricht einem Control der ACP-Checkliste (`assessment/assessment-checklist.md`, Englisch). Die Control-IDs sind in beiden Sprachen identisch. Die Leitfragen helfen, **pro Control eine Bewertung** festzulegen. Die Fragen werden nicht einzeln bewertet.

Framework-Version: **ACP 2.3**

Anleitung

1. Füllen Sie das Organisationsprofil aus und bestätigen Sie den Scope des Assessments, einschliesslich der Frage, ob die Domäne KI-Sicherheit (Domäne 11) anwendbar ist.
2. Gehen Sie für jedes Control die Leitfragen mit den verantwortlichen Personen durch. Ist der IT-Betrieb ausgelagert, beziehen Sie den IT-Dienstleister ein; die Verantwortung bleibt bei der Organisation.
3. Lassen Sie sich die in der Bewertungshilfe genannten Nachweise zeigen und halten Sie fest, was geprüft wurde (Dokumentname, System, Screenshot, Interview).
4. Vergeben Sie pro Control eine Bewertung. Verwenden Sie N/A nur, wo das Scoring-Modell dies zulässt.
5. Berechnen Sie die Domänen-Scores und den ACP-Gesamtscore gemäss `assessment/scoring-model.md` (Englisch).

Score	Bedeutung	Beschreibung
0	Nicht umgesetzt	Das Control existiert nicht, ist nicht umgesetzt, oder es liegt kein Nachweis vor.
1	Teilweise umgesetzt	Das Control existiert, ist aber unvollständig, wird uneinheitlich angewendet oder deckt nur einen Teil des Scopes ab.
2	Umgesetzt	Das Control ist im gesamten Scope umgesetzt und dokumentiert, und Nachweise belegen, dass es wirksam betrieben wird.
3	Aktiv gesteuert	Zusätzlich wird das Control überwacht, in festgelegten Abständen überprüft und laufend verbessert.

Mit **[KO]** markierte Controls sind Knock-out-Controls. Eine Bewertung von 0 schliesst die Zertifizierung aus. Knock-out-Controls können nicht als N/A markiert werden.

Bewertungshilfe. Die Spalte *Bewertungshilfe* nennt typische Nachweise und was eine Bewertung von 2 typischerweise von 3 unterscheidet. Sie unterstützt das Urteil des Assessors, ersetzt es aber nicht. Score 1 gilt, wenn das Control nur teilweise vorhanden ist.

Controls mit mehreren Teilen. Umfasst ein Control mehrere Aspekte, bestimmt der schwächste wesentliche Aspekt den Score.

Verhältnismässigkeit. Kleine Organisationen brauchen keine umfangreiche Dokumentation. Kurze, klare Regeln genügen, wenn sie gelebt werden und sich zeigen lassen.

Angaben zum Assessment

Organisation:

Datum des Assessments:

Assessor:

Domäne KI-Sicherheit anwendbar: □ Ja □ Nein

Organisationsprofil

Das Profil beschreibt den Kontext des Assessments. Es wird nicht bewertet.

Thema	Angabe
Anzahl Mitarbeitende und Standorte	
IT-Betrieb (intern, IT-Dienstleister, gemischt)	
Wichtigste Cloud- und SaaS-Dienste (z. B. Microsoft 365)	
Nutzung von KI-Tools oder KI-Systemen	
Anwendbare Regulierung (z. B. NIS2, ISG, DSG/DSGVO, DORA, EU Cyber Resilience Act)	
Kunden aus regulierten Branchen (z. B. Finanzsektor nach DORA)	
Sicherheitsvorfälle in den letzten 12 Monaten	
Cyberversicherung	
Bestehende Zertifizierungen oder Audits (z. B. ISO/IEC 27001)	

Domäne 1 – Unternehmens- und Sicherheits-Governance (kritisch)

Englisch: Business & Security Governance

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
1.1	Eine Cybersecurity-Strategie ist dokumentiert	• Ist eine dokumentierte Cybersecurity- oder Informationssicherheitsstrategie vorhanden? • Wurde die Strategie von der Geschäftsleitung genehmigt? • Wann wurde die Strategie zuletzt überprüft?	**Zeigen lassen:** Strategiedokument mit Genehmigungsdatum **2:** Strategie dokumentiert und von der Geschäftsleitung genehmigt **3:** Mindestens jährlich überprüft und an Veränderungen angepasst		
1.2	Cybersecurity-Ziele sind definiert und auf die Geschäftsziele abgestimmt	• Sind Cybersecurity-Ziele definiert und dokumentiert? • Sind die Ziele aus den Geschäftszielen abgeleitet? • Werden die Ziele regelmässig überprüft?	**Zeigen lassen:** Liste der Sicherheitsziele **2:** Ziele definiert und mit den Geschäftszielen verknüpft **3:** Zielerreichung wird gemessen, Ziele werden regelmässig überprüft		
1.3	Sicherheitsverantwortlichkeiten sind in der Organisation zugewiesen	• Sind Verantwortlichkeiten für Cybersecurity definiert? • Ist eine verantwortliche Person für Cybersecurity benannt (z. B. CISO, Informationssicherheitsbeauftragte)? • Sind Stellvertretungen geregelt?	**Zeigen lassen:** Organigramm oder Rollenbeschreibung mit Sicherheitsverantwortung **2:** Verantwortliche Person und Stellvertretung benannt, Aufgaben festgelegt **3:** Verantwortlichkeiten werden überprüft, die Rolle hat ausreichend Zeit und Budget		
1.4	Sicherheitsthemen werden auf Ebene der Geschäftsleitung besprochen	• Werden Cybersecurity-Themen regelmässig in Sitzungen der Geschäftsleitung besprochen? • Werden Entscheidungen zur Cybersecurity dokumentiert?	**Zeigen lassen:** Protokolle von Sitzungen der Geschäftsleitung mit Sicherheitsthemen **2:** Sicherheit wird mindestens quartalsweise besprochen, Entscheide werden festgehalten **3:** Fester Traktandenpunkt, die Umsetzung der Entscheide wird verfolgt		
1.5	Sicherheitsinitiativen werden geplant und verfolgt	• Gibt es eine Roadmap für Sicherheitsmassnahmen? • Haben die Massnahmen Verantwortliche, Budgets und Termine? • Wird der Fortschritt verfolgt?	**Zeigen lassen:** Sicherheits-Roadmap oder Massnahmenliste **2:** Massnahmen haben Verantwortliche, Termine und Budget **3:** Fortschritt wird regelmässig überprüft, Prioritäten werden angepasst		
1.6	Es gibt ein Sicherheitsreporting an die Geschäftsleitung	• Erhält die Geschäftsleitung regelmässig Sicherheitsberichte? • Werden die Ergebnisse von Sicherheitsassessments an die Geschäftsleitung kommuniziert?	**Zeigen lassen:** Letzter Sicherheitsbericht an die Geschäftsleitung **2:** Die Geschäftsleitung erhält mindestens halbjährlich einen Sicherheitsbericht **3:** Berichte enthalten Kennzahlen und Trends und führen zu dokumentierten Entscheiden		

Domänen-Score:

Domäne 2 – Risikomanagement

Englisch: Risk Management

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
2.1	Cybersecurity-Risiken werden formell identifiziert	• Gibt es einen Prozess zur Identifikation von Cybersecurity-Risiken? • Werden Risiken bei neuen Projekten, Systemen oder Diensten beurteilt und bei Änderungen an Systemen oder Prozessen neu bewertet? • Werden Cloud-Risiken berücksichtigt?	**Zeigen lassen:** Beschreibung des Risikoprozesses, letzte Risikoidentifikation **2:** Risiken werden nach einem festgelegten Vorgehen identifiziert **3:** Neubeurteilung nach Änderungen und mindestens jährlich		
2.2	Ein Risikoregister ist vorhanden	• Wird ein Risikoregister geführt? • Hat jedes Risiko eine verantwortliche Person?	**Zeigen lassen:** Risikoregister **2:** Register ist aktuell, jedes Risiko hat eine verantwortliche Person **3:** Register dient als Entscheidungsgrundlage und wird regelmässig nachgeführt		
2.3	Risiken werden nach Auswirkung und Eintrittswahrscheinlichkeit bewertet	• Ist eine dokumentierte Methodik zur Risikobewertung vorhanden? • Werden Risiken nach Eintrittswahrscheinlichkeit und Auswirkung bewertet?	**Zeigen lassen:** Bewertungsskala und bewertete Risiken **2:** Alle Risiken sind nach einer dokumentierten Skala bewertet **3:** Bewertungen sind nachvollziehbar und werden bei veränderter Lage überprüft		
2.4	Massnahmen zur Risikominderung sind definiert	• Sind für relevante Risiken Massnahmen zur Risikominderung definiert? • Wird die Umsetzung der Massnahmen bis zum Abschluss verfolgt? • Wird die Akzeptanz von Restrisiken formell genehmigt? • Wird ein Risikotransfer (z. B. Cyberversicherung) geprüft, und sind die Auflagen und Meldepflichten der Versicherung bekannt?	**Zeigen lassen:** Massnahmenplan, akzeptierte Restrisiken **2:** Für relevante Risiken sind Massnahmen definiert, Restrisiken sind formell akzeptiert **3:** Wirksamkeit der Massnahmen wird überprüft, Risikotransfer (z. B. Versicherung) wird bewusst geprüft		
2.5	Risiken werden periodisch überprüft	• Werden Risiken in festgelegten Abständen überprüft? • Wann fand die letzte Überprüfung statt?	**Zeigen lassen:** Datum und Ergebnis der letzten Risikoüberprüfung **2:** Risiken werden mindestens jährlich überprüft **3:** Zusätzlich anlassbezogene Überprüfungen (z. B. nach Vorfällen oder Änderungen)		

2.6	Lieferkettenrisiken werden bewertet, und mit kritischen Lieferanten sind Sicherheitsanforderungen vereinbart	• Sind kritische Lieferanten und Dienstleister identifiziert? • Werden deren Sicherheitsrisiken und -praktiken vor und während der Zusammenarbeit bewertet, einschliesslich der Entwicklungspraktiken von Softwarelieferanten? • Sind Sicherheitsanforderungen in den Verträgen mit kritischen Lieferanten enthalten? • Falls der IT-Betrieb ausgelagert ist (z. B. an einen IT-Dienstleister): Sind die Verantwortlichkeiten für die Sicherheit schriftlich geregelt? • Falls Sie Kunden aus dem Finanzsektor haben (z. B. nach DORA): Sind Ihre vertraglichen Pflichten bekannt, und können Sie sie erfüllen (z. B. Meldung und Unterstützung bei Vorfällen, Zugangs- und Prüfrechte, Mitwirkung bei Tests, Ausstiegsunterstützung mit Rückgabe der Daten)? • Falls Sie Kunden aus dem Finanzsektor haben: Können Sie die Angaben liefern, die diese für ihr Informationsregister benötigen (z. B. Standorte der Leistungserbringung und Datenverarbeitung, Unterauftragnehmer)?	**Zeigen lassen:** Liste der kritischen Lieferanten, Vertragsklauseln **2:** Kritische Lieferanten (inkl. IT-Dienstleister) sind bekannt, Sicherheitsanforderungen sind vertraglich geregelt **3:** Lieferanten werden periodisch überprüft (z. B. Fragebogen, Zertifikate)		

Domänen-Score:

Domäne 3 – Sicherheitsrichtlinien und -prozesse

Englisch: Security Policies & Processes

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
3.1	Eine Informationssicherheitsrichtlinie ist vorhanden	• Ist eine Informationssicherheitsrichtlinie dokumentiert und zugänglich? • Wurde sie von der Geschäftsleitung genehmigt? • Wird sie regelmässig überprüft?	**Zeigen lassen:** Informationssicherheitsrichtlinie mit Genehmigung **2:** Richtlinie genehmigt und für alle Mitarbeitenden zugänglich **3:** Mindestens jährlich überprüft und bei Änderungen nachgeführt		
3.2	Nutzungsrichtlinien sind definiert	• Ist eine Nutzungsrichtlinie (Acceptable Use Policy) vorhanden? • Sind Regeln für die Nutzung von IT-Systemen, Cloud-Diensten und Messenger-Diensten definiert, auch für das Arbeiten ausserhalb des Büros (z. B. Homeoffice, Reisen)? • Werden neue Cloud-Dienste erst nach einer Freigabe genutzt? • Sind Regeln für die Nutzung von KI-Tools festgelegt (z. B. welche Tools erlaubt sind und welche Daten nicht eingegeben werden dürfen)?	**Zeigen lassen:** Nutzungsrichtlinie inkl. Regeln für KI-Tools **2:** Regeln für IT, Cloud-Dienste und KI-Tools sind festgelegt und bekannt **3:** Einhaltung wird überprüft, Regeln werden für neue Tools angepasst		
3.3	Backup-Richtlinien sind dokumentiert	• Ist eine Backup-Richtlinie vorhanden? • Legt sie Umfang, Häufigkeit, Aufbewahrungsdauer und Verantwortlichkeiten für die Wiederherstellung fest?	**Zeigen lassen:** Backup-Richtlinie **2:** Umfang, Häufigkeit, Aufbewahrung und Verantwortlichkeiten sind festgelegt **3:** Richtlinie ist auf die Wiederanlaufziele abgestimmt und wird regelmässig überprüft		
3.4	Verfahren für das Patch-Management sind vorhanden	• Ist ein Patch-Management-Prozess definiert? • Legt er Fristen abhängig vom Schweregrad fest?	**Zeigen lassen:** Verfahren für das Patch-Management **2:** Fristen nach Schweregrad sind festgelegt (z. B. kritisch innert Tagen) **3:** Einhaltung der Fristen wird gemessen und berichtet		
3.5	Verfahren zur Reaktion auf Sicherheitsvorfälle sind definiert	• Ist ein Verfahren zur Reaktion auf Sicherheitsvorfälle dokumentiert? • Legt es Rollen, Meldewege und Meldepflichten fest?	**Zeigen lassen:** Verfahren zur Reaktion auf Sicherheitsvorfälle **2:** Rollen, Meldewege und Meldepflichten sind festgelegt **3:** Verfahren wird getestet und nach Tests oder Vorfällen angepasst		
3.6	Sicherheitsverantwortlichkeiten sind mit den Mitarbeitenden vereinbart, und Sicherheitsverfahren werden ihnen kommuniziert	• Sind Sicherheitspflichten und Vertraulichkeit in Arbeitsverträgen oder separaten Vereinbarungen geregelt? • Werden für Rollen mit Zugang zu sensiblen Informationen Hintergrundprüfungen durchgeführt, soweit rechtlich zulässig? • Werden die Mitarbeitenden über Sicherheitsrichtlinien und -verfahren informiert, und bestätigen sie die Kenntnisnahme?	**Zeigen lassen:** Vorlage Arbeitsvertrag, unterzeichnete Bestätigungen **2:** Sicherheits- und Vertraulichkeitspflichten sind vereinbart, Mitarbeitende bestätigen die Regeln **3:** Regeln werden regelmässig aufgefrischt (z. B. jährliche Bestätigung)		

3.7	Zahlungsfreigaben und Änderungen von Bankverbindungen sind gegen Betrug abgesichert (Vier-Augen-Prinzip, Rückbestätigung über einen bekannten Kontakt)	• Werden Zahlungen ab einem festgelegten Betrag von zwei Personen freigegeben? • Werden Änderungen von Bankverbindungen bei Lieferanten oder Mitarbeitenden durch Rückruf unter einer bekannten Nummer bestätigt (nicht über die Kontaktdaten aus der Anfrage)? • Kennen die Mitarbeitenden in Buchhaltung und Geschäftsleitung aktuelle Betrugsmuster (z. B. CEO-Fraud, gefälschte Rechnungen)? • Wissen sie, dass Stimmen und Videos mit KI gefälscht werden können (Deepfakes), und gilt der Rückruf unter einer bekannten Nummer auch dann, wenn die anrufende Person vertraut klingt?	**Zeigen lassen:** Regelung der Zahlungsfreigabe, Ablauf bei Änderungen von Bankverbindungen **2:** Vier-Augen-Prinzip und Rückbestätigung sind festgelegt und werden angewendet **3:** Ablauf wird geübt (z. B. in Schulungen zu Betrugsmustern), Ausnahmen werden dokumentiert		

Domänen-Score:

Domäne 4 – Identitäts- und Zugriffsmanagement (kritisch)

Englisch: Identity & Access Management

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
4.1	Die Verwaltung von Benutzerkonten ist geregelt	• Gibt es einen definierten Prozess zum Erstellen, Ändern und Entfernen von Benutzerkonten? • Sind alle Konten personenbezogen (keine geteilten Konten)? • Sind Passwörter durch klare Regeln geschützt (z. B. Passwort-Manager, keine Wiederverwendung), und werden Standardpasswörter auf Geräten wie Routern, Druckern und Kameras geändert?	**Zeigen lassen:** Ein-, Um- und Austrittsprozess, Benutzerliste **2:** Konten werden nur über den festgelegten Prozess erstellt und geändert, keine geteilten Konten **3:** Prozess wird regelmässig auf Abweichungen geprüft		
4.2	Rollenbasierte Zugriffskontrolle ist umgesetzt	• Werden Zugriffsrechte anhand von Rollen vergeben? • Wird das Prinzip der minimalen Rechte angewendet?	**Zeigen lassen:** Rollen- und Berechtigungskonzept **2:** Rechte werden nach Rollen und dem Prinzip der minimalen Rechte vergeben **3:** Rollen werden regelmässig überprüft und angepasst		
4.3	Für Fernzugriff, Cloud-Dienste und administrative Konten wird Multi-Faktor-Authentifizierung eingesetzt **[KO]**	• Ist MFA für Fernzugriff, Cloud-Dienste und E-Mail erzwungen? • Ist MFA für alle administrativen Konten erzwungen? • Sind Ausnahmen dokumentiert und genehmigt? • Werden für Administratoren phishing-resistente Verfahren eingesetzt (z. B. FIDO2-Sicherheitsschlüssel, Passkeys), und sind veraltete Anmeldeverfahren ohne MFA blockiert?	**Zeigen lassen:** MFA-Konfiguration (z. B. Richtlinien für bedingten Zugriff), Liste der Ausnahmen **2:** MFA ist für Fernzugriff, Cloud-Dienste, E-Mail und alle Administratoren erzwungen **3:** Zusätzlich phishing-resistente MFA für Administratoren, veraltete Anmeldeverfahren blockiert, Ausnahmen werden überprüft		
4.4	Privilegierte Konten sind eingeschränkt und werden überwacht **[KO]**	• Sind privilegierte Konten von den Konten für die tägliche Arbeit getrennt? • Ist die Anzahl privilegierter Konten begrenzt? • Werden privilegierte Aktivitäten protokolliert und überprüft? • Ist der administrative Zugriff externer Dienstleister mit MFA geschützt, auf das Nötige beschränkt und protokolliert? • Sind Dienstkonten, technische Konten und API-Schlüssel bekannt, auf die nötigen Rechte beschränkt und geschützt (z. B. Geheimnisse sicher gespeichert und geändert, wenn Personen austreten, die sie kennen)?	**Zeigen lassen:** Liste der privilegierten Konten (inkl. Konten von Dienstleistern und Dienstkonten), Protokoll privilegierter Aktivitäten **2:** Getrennte Admin-Konten, begrenzte Anzahl, MFA, Zugriff von Dienstleistern geregelt, Dienstkonten und API-Schlüssel bekannt und eingeschränkt, privilegierte Aktivitäten werden protokolliert **3:** Privilegierte Aktivitäten werden regelmässig überprüft, nicht mehr benötigte Konten und Schlüssel werden entfernt		
4.5	Zugriffsrechte werden periodisch überprüft	• Werden Zugriffsrechte in festgelegten Abständen überprüft? • Werden die Ergebnisse dokumentiert und Korrekturen umgesetzt?	**Zeigen lassen:** Letzte Rechteüberprüfung mit Ergebnis **2:** Rechte werden mindestens jährlich überprüft, Korrekturen werden umgesetzt **3:** Risikobasiert (bei kritischen Systemen häufiger) und vollständig dokumentiert		

4.6	Benutzerkonten werden beim Austritt von Mitarbeitenden entfernt	• Werden Konten beim Austritt oder Rollenwechsel zeitnah deaktiviert? • Ist der Prozess mit der Personalabteilung verknüpft?	**Zeigen lassen:** Austritts-Checkliste, Stichprobe der letzten Austritte **2:** Konten werden spätestens am letzten Arbeitstag deaktiviert **3:** Prozess ist mit der Personalabteilung verknüpft und wird stichprobenartig geprüft		

Domänen-Score:

Domäne 5 – Infrastruktursicherheit

Englisch: Infrastructure Security

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
5.1	Ein Inventar der Systeme und Server ist vorhanden	• Wird ein Inventar der Server, Systeme und Cloud-Ressourcen geführt? • Ist es aktuell, und hat jedes System eine verantwortliche Person? • Umfasst das Inventar auch Netzwerkgeräte, Drucker, Kameras und andere IoT- oder OT-Geräte?	**Zeigen lassen:** Systeminventar **2:** Inventar ist vollständig und aktuell, jedes System hat eine verantwortliche Person **3:** Inventar wird automatisch nachgeführt oder regelmässig mit der Realität abgeglichen		
5.2	Standards für sichere Konfiguration sind definiert	• Sind Standards für sichere Konfigurationen (Härtungsvorgaben) definiert? • Basieren sie auf anerkannten Benchmarks (z. B. CIS Benchmarks)? • Wird die Einhaltung der Standards überprüft?	**Zeigen lassen:** Härtungsvorgaben, Compliance-Bericht **2:** Vorgaben sind festgelegt und werden bei neuen Systemen angewendet **3:** Einhaltung wird regelmässig (z. B. automatisiert) geprüft, Abweichungen werden behoben		
5.3	Systeme werden regelmässig gepatcht und aktualisiert **[KO]**	• Werden Sicherheitsupdates innerhalb festgelegter Fristen eingespielt? • Werden kritische Schwachstellen priorisiert behoben? • Werden nicht mehr unterstützte Systeme identifiziert und behandelt?	**Zeigen lassen:** Bericht zum Patch-Stand **2:** Updates werden innerhalb der festgelegten Fristen eingespielt, nicht unterstützte Systeme sind bekannt **3:** Patch-Stand wird gemessen, nicht unterstützte Systeme werden ersetzt oder isoliert		
5.4	Der administrative Zugriff auf Systeme ist eingeschränkt	• Ist der administrative Zugriff auf berechtigte Personen und dedizierte Zugriffswege beschränkt? • Sind Administrationsschnittstellen vor direktem Zugriff aus dem Internet geschützt?	**Zeigen lassen:** Zugriffswege für Administratoren, Firewall-Regeln für Verwaltungsschnittstellen **2:** Admin-Zugriff nur für Berechtigte über festgelegte Wege, keine Verwaltungsschnittstellen aus dem Internet erreichbar **3:** Admin-Zugriff wird regelmässig überprüft (z. B. Jump Host, zeitlich begrenzte Rechte)		
5.5	Änderungen an Systemen und Software werden dokumentiert und genehmigt; wird Software entwickelt oder in Auftrag gegeben, folgt dies sicheren Entwicklungspraktiken	• Werden Änderungen an Systemen und Software dokumentiert und genehmigt? • Ist ein Change-Management-Prozess vorhanden? • Falls Software selbst entwickelt oder in Auftrag gegeben wird: Sind sichere Entwicklungspraktiken festgelegt (z. B. sicheres Programmieren, Sicherheitstests, Trennung von Entwicklung und Produktion)?	**Zeigen lassen:** Änderungsprotokolle, Vorgaben zur sicheren Entwicklung (falls zutreffend) **2:** Änderungen werden dokumentiert und genehmigt, bei Software-Entwicklung gelten sichere Entwicklungspraktiken **3:** Änderungen werden auf Sicherheitsauswirkungen geprüft, Entwicklungspraktiken werden überprüft (z. B. Code-Review, Tests)		
5.6	Die Cloud-Infrastruktur folgt Vorgaben für sichere Konfiguration	• Sind Cloud-Umgebungen nach bewährten Sicherheitspraktiken konfiguriert? • Wird die Sicherheitslage der Cloud überwacht (z. B. Secure Score, Posture Management)? • Sind bei Cloud- und SaaS-Diensten (z. B. Microsoft 365) externe Freigaben und Berechtigungen für Drittanwendungen eingeschränkt?	**Zeigen lassen:** Secure Score oder Konfigurationsbericht der Cloud **2:** Cloud- und SaaS-Dienste folgen einer festgelegten sicheren Konfiguration, externe Freigaben sind eingeschränkt **3:** Konfiguration wird laufend überwacht, Abweichungen werden behoben		

5.7	Aus dem Internet erreichbare Systeme sind bekannt, auf das Nötige beschränkt und werden priorisiert gepatcht	• Gibt es eine aktuelle Liste aller aus dem Internet erreichbaren Systeme und Dienste (z. B. Firewalls, VPN-Gateways, Fernzugänge, Webseiten, Mailserver)? • Wird die Erreichbarkeit von aussen regelmässig geprüft (z. B. externer Scan), und werden nicht benötigte Dienste geschlossen? • Werden Sicherheitsupdates für diese Systeme innert weniger Tage eingespielt, insbesondere bei aktiv ausgenutzten Schwachstellen?	**Zeigen lassen:** Liste der aus dem Internet erreichbaren Systeme, Ergebnis eines externen Scans **2:** Alle erreichbaren Systeme sind bekannt, nicht benötigte Dienste geschlossen, kritische Updates innert Tagen **3:** Erreichbarkeit wird regelmässig geprüft (z. B. monatlicher Scan), Warnungen zu aktiv ausgenutzten Schwachstellen werden verfolgt		

Domänen-Score:

Domäne 6 – Endgerätesicherheit

Englisch: Endpoint Security

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
6.1	Software für den Endgeräteschutz ist installiert	• Ist auf allen Endgeräten ein Endgeräteschutz (Antivirus oder EDR) installiert? • Wird dessen Status zentral überwacht? • Wird der Zugriff auf bekannte schädliche Websites und Downloads blockiert (z. B. Web- oder DNS-Filter), auch ausserhalb des Büros?	**Zeigen lassen:** Konsole des Endgeräteschutzes **2:** Schutz ist auf allen Endgeräten aktiv, der Status wird zentral überwacht **3:** Alarme werden zeitnah bearbeitet, EDR mit Reaktionsmöglichkeiten ist im Einsatz		
6.2	Geräte werden zentral verwaltet	• Werden die Geräte zentral verwaltet (z. B. MDM/UEM)? • Werden Compliance-Richtlinien durchgesetzt? • Arbeiten die Benutzer ohne lokale Administratorrechte, und wird die Installation nicht genehmigter Software (z. B. Fernwartungs-Tools) verhindert?	**Zeigen lassen:** Konsole der Geräteverwaltung, Richtlinien **2:** Alle Geräte werden zentral verwaltet, Benutzer haben keine lokalen Administratorrechte **3:** Compliance wird durchgesetzt (nicht konforme Geräte werden blockiert), nicht genehmigte Software wird verhindert		
6.3	Festplattenverschlüsselung ist auf Endgeräten aktiviert	• Ist die Festplattenverschlüsselung auf allen Laptops und Desktops aktiviert? • Werden die Wiederherstellungsschlüssel sicher aufbewahrt?	**Zeigen lassen:** Bericht zum Verschlüsselungsstatus **2:** Alle Laptops und Desktops sind verschlüsselt, Wiederherstellungsschlüssel sind zentral gesichert **3:** Status wird überwacht, unverschlüsselte Geräte werden automatisch erkannt		
6.4	Updates für Endgeräte werden automatisch verteilt	• Werden Updates für Betriebssysteme und Anwendungen automatisch verteilt? • Wird der Update-Stand überwacht?	**Zeigen lassen:** Bericht zum Update-Stand **2:** Updates werden automatisch verteilt **3:** Update-Stand wird überwacht, veraltete Geräte werden nachverfolgt		
6.5	Mobile Geräte werden sicher verwaltet	• Werden mobile Geräte verwaltet? • Sind Unternehmensdaten auf privaten Geräten geschützt?	**Zeigen lassen:** Verwaltung mobiler Geräte, Regelung für private Geräte **2:** Firmen-Smartphones werden verwaltet, Firmendaten auf privaten Geräten sind geschützt (z. B. App-Schutz) **3:** Compliance mobiler Geräte wird geprüft und durchgesetzt		
6.6	Verlorene oder gestohlene Geräte können aus der Ferne gesteuert oder gelöscht werden	• Können verlorene oder gestohlene Geräte aus der Ferne gesperrt oder gelöscht werden? • Gibt es einen Prozess zur Meldung verlorener Geräte? • Werden Geräte und Datenträger vor Entsorgung, Verkauf oder Rückgabe (z. B. am Ende eines Leasings) sicher gelöscht oder vernichtet?	**Zeigen lassen:** Funktion zum Sperren und Löschen aus der Ferne, Meldeprozess **2:** Geräte können aus der Ferne gesperrt und gelöscht werden, Verlustmeldung ist geregelt **3:** Funktion wurde getestet, Verluste werden innert Stunden behandelt		

Domänen-Score:

Domäne 7 – Netzwerksicherheit

Englisch: Network Security

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
7.1	Netzwerk-Firewalls sind im Einsatz	• Sind an den Netzwerkgrenzen Firewalls im Einsatz? • Werden die Firewall-Regeln regelmässig überprüft?	**Zeigen lassen:** Firewall-Regelwerk, letzte Regelüberprüfung **2:** Firewalls schützen alle Netzwerkgrenzen, Regeln sind dokumentiert **3:** Regeln werden regelmässig überprüft, nicht benötigte Regeln werden entfernt		
7.2	Netzwerksegmentierung wird eingesetzt, wo sinnvoll	• Sind die Netzwerke segmentiert (z. B. Server, Clients, Gäste)? • Sind kritische Systeme isoliert?	**Zeigen lassen:** Netzwerkplan mit Segmenten **2:** Server, Clients, Gäste und (falls vorhanden) OT- oder IoT-Geräte sind getrennt **3:** Verkehr zwischen Segmenten ist auf das Nötige beschränkt und wird überprüft		
7.3	Sicherer Fernzugriff (z. B. VPN oder Zero Trust Network Access) ist umgesetzt	• Erfolgt der Fernzugriff über sichere Lösungen (VPN oder ZTNA)? • Ist der Fernzugriff auf berechtigte Benutzer und Geräte beschränkt?	**Zeigen lassen:** Konfiguration des Fernzugriffs **2:** Fernzugriff nur über eine sichere Lösung mit MFA und für Berechtigte **3:** Zusätzlich Prüfung des Geräts (z. B. ZTNA, Compliance-Prüfung), Zugänge werden regelmässig überprüft		
7.4	Der Netzwerkverkehr wird überwacht	• Wird der Netzwerkverkehr auf verdächtige Aktivitäten überwacht? • Werden Systeme zur Erkennung oder Verhinderung von Angriffen (IDS/IPS) eingesetzt?	**Zeigen lassen:** Monitoring-Dashboard, Beispielalarm **2:** Netzwerkverkehr wird auf verdächtige Aktivitäten überwacht **3:** Alarme werden ausgewertet und bearbeitet, Erkennungsregeln werden gepflegt		
7.5	Drahtlosnetzwerke sind sicher konfiguriert	• Sind WLANs mit aktueller Verschlüsselung gesichert (z. B. WPA2/WPA3 Enterprise)? • Ist das Gäste-WLAN von den internen Netzwerken getrennt?	**Zeigen lassen:** WLAN-Konfiguration **2:** Aktuelle Verschlüsselung, Gäste-WLAN getrennt **3:** Enterprise-Authentifizierung (802.1X), fremde Access Points werden erkannt		
7.6	Der Netzwerkzugang ist auf berechtigte Geräte beschränkt	• Ist der Netzwerkzugang auf berechtigte Geräte beschränkt (z. B. NAC, 802.1X)? • Werden unbekannte Geräte erkannt?	**Zeigen lassen:** Konfiguration der Netzwerkzugangskontrolle **2:** Nur bekannte Geräte erhalten Netzwerkzugang **3:** Unbekannte Geräte werden automatisch erkannt und blockiert		
7.7	E-Mail ist gegen Phishing, Absenderfälschung und Schadsoftware geschützt	• Werden eingehende E-Mails auf Phishing, schädliche Links und Anhänge gefiltert? • Sind SPF, DKIM und DMARC für die eigenen Domains eingerichtet (DMARC mit einer durchsetzenden Richtlinie)? • Werden externe E-Mails gekennzeichnet, und können Mitarbeitende verdächtige E-Mails einfach melden?	**Zeigen lassen:** Einstellungen des E-Mail-Filters, DMARC-Eintrag (z. B. DNS-Abfrage) **2:** Filter aktiv, SPF, DKIM und DMARC eingerichtet, externe E-Mails gekennzeichnet **3:** DMARC wird durchgesetzt (Quarantäne oder Ablehnung), Berichte werden ausgewertet, gemeldete E-Mails werden analysiert		

Domänen-Score:

Domäne 8 – Datensicherheit, Backup und Wiederherstellung (kritisch)

Englisch: Data Protection, Backup & Recovery

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
8.1	Sensible Daten sind identifiziert und klassifiziert	• Sind sensible Daten identifiziert? • Ist ein Klassifizierungsschema für Daten vorhanden, und wird es angewendet?	**Zeigen lassen:** Klassifizierungsschema, Übersicht der sensiblen Daten **2:** Sensible Daten sind identifiziert und klassifiziert **3:** Klassifizierung wird im Alltag angewendet (z. B. Labels) und überprüft		
8.2	Sensible Daten werden auf Basis einer festgelegten Kryptografie-Richtlinie verschlüsselt	• Ist eine Kryptografie-Richtlinie festgelegt (z. B. zugelassene Algorithmen, Schlüssellängen, Schlüsselverwaltung)? • Werden sensible Daten gemäss dieser Richtlinie bei der Speicherung und Übertragung verschlüsselt? • Werden die Schlüssel sicher verwaltet?	**Zeigen lassen:** Kryptografie-Richtlinie, Verschlüsselungseinstellungen **2:** Richtlinie festgelegt, sensible Daten bei Speicherung und Übertragung verschlüsselt **3:** Schlüsselverwaltung ist geregelt, Einhaltung der Richtlinie wird überprüft		
8.3	Sichere Verfahren zur Dateiübertragung werden eingesetzt	• Werden sichere Verfahren zur Dateiübertragung eingesetzt (z. B. SFTP, sichere Austauschplattformen)? • Sind unsichere Übertragungsverfahren untersagt?	**Zeigen lassen:** Zugelassene Übertragungswege **2:** Sichere Verfahren sind verfügbar und werden genutzt, unsichere sind untersagt **3:** Nutzung wird überwacht (z. B. Data Loss Prevention)		
8.4	Backup-Verfahren sind umgesetzt und getestet **[KO]**	• Werden Backups gemäss der Backup-Richtlinie durchgeführt? • Werden Wiederherstellungen regelmässig getestet und dokumentiert? • Sind Daten aus Cloud- und SaaS-Diensten (z. B. Microsoft 365) in die Datensicherung einbezogen?	**Zeigen lassen:** Backup-Bericht, Protokoll des letzten Wiederherstellungstests **2:** Backups laufen planmässig, inkl. Cloud- und SaaS-Daten, Wiederherstellung wurde getestet **3:** Regelmässige Wiederherstellungstests mit gemessener Dauer, auch für ganze Systeme		
8.5	Backup-Daten sind vor unberechtigtem Zugriff und Manipulation geschützt **[KO]**	• Sind Backups gegen unberechtigten Zugriff und Ransomware geschützt (z. B. Offline- oder unveränderbare Kopien, separate Zugangsdaten)? • Wird mindestens eine Backup-Kopie an einem separaten Standort aufbewahrt?	**Zeigen lassen:** Backup-Architektur (Offline- oder unveränderbare Kopie, Zugangsdaten) **2:** Mindestens eine Offline- oder unveränderbare Kopie an separatem Standort, separate Zugangsdaten **3:** Schutz wird getestet (z. B. Angriffsszenario) und überwacht		
8.6	Dateien, die ausserhalb geschützter Systeme ausgetauscht oder archiviert werden, sind mit aktuellen Algorithmen verschlüsselt (z. B. AES-256)	• Werden Dateien, die ausserhalb geschützter Systeme ausgetauscht oder archiviert werden, verschlüsselt? • Werden aktuelle Algorithmen verwendet (z. B. AES-256)?	**Zeigen lassen:** Verschlüsselungswerkzeug, Beispiel eines verschlüsselten Austauschs **2:** Dateien ausserhalb geschützter Systeme werden mit aktuellen Algorithmen verschlüsselt **3:** Nutzung wird technisch durchgesetzt oder überprüft		

8.7	Notfall- und Wiederherstellungspläne (Business Continuity und Disaster Recovery) sind dokumentiert und getestet	• Sind kritische Geschäftsprozesse und IT-Systeme identifiziert, mit festgelegten Zielen für Wiederanlaufzeit und maximalen Datenverlust (RTO/RPO)? • Sind für diese Prozesse und Systeme Notfall- und Wiederherstellungspläne dokumentiert? • Werden die Pläne regelmässig getestet (z. B. Wiederherstellungstests, Planspiele), und werden die Ergebnisse dokumentiert? • Falls Sie Kunden aus dem Finanzsektor haben: Sind Ihre Wiederanlaufziele auf die Anforderungen der Kunden abgestimmt, für die Ihre Leistung kritisch ist, und werden die Pläne getestet?	**Zeigen lassen:** Business-Impact-Analyse, Notfall- und Wiederherstellungspläne, Testbericht **2:** Kritische Prozesse mit RTO/RPO identifiziert, Pläne dokumentiert und mindestens einmal getestet **3:** Pläne werden mindestens jährlich getestet, Ergebnisse führen zu Verbesserungen		
8.8	Krisenmanagement und Notfallkommunikation sind festgelegt	• Ist ein Krisenstab mit Rollen und Entscheidungsbefugnissen festgelegt? • Sind Kommunikationswege für den Notfall festgelegt, die auch bei Ausfall der primären IT-Systeme funktionieren? • Sind die Kontaktlisten für interne und externe Stellen (z. B. Behörden, Versicherungen, wichtige Lieferanten) aktuell?	**Zeigen lassen:** Krisenplan, Kontaktliste (ausgedruckt oder offline) **2:** Krisenstab, Entscheidungsbefugnisse und Notfallkommunikation festgelegt, Kontaktliste aktuell **3:** Krisenübung durchgeführt, Plan und Kontakte werden regelmässig überprüft		

Domänen-Score:

Domäne 9 – Monitoring und Vorfallbehandlung (kritisch)

Englisch: Monitoring & Incident Response

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
9.1	Sicherheitsprotokolle werden gesammelt	• Werden Sicherheitsprotokolle (Logs) der relevanten Systeme gesammelt? • Werden die Logs zentral gespeichert und für eine festgelegte Dauer aufbewahrt? • Sind die Audit-Logs von Cloud-Diensten (z. B. Microsoft 365) aktiviert und ausreichend lange aufbewahrt?	**Zeigen lassen:** Log-Quellen, Aufbewahrungseinstellungen **2:** Logs der relevanten Systeme inkl. Cloud-Audit-Logs werden zentral gesammelt und aufbewahrt **3:** Vollständigkeit der Log-Quellen wird regelmässig geprüft		
9.2	Die Logs werden überwacht	• Werden die Logs überwacht? • Ist die Überwachung automatisiert (z. B. SIEM)?	**Zeigen lassen:** Monitoring-Werkzeug oder SIEM, Beispielauswertung **2:** Logs werden nach festgelegten Regeln überwacht **3:** Überwachung ist automatisiert, Regeln werden an neue Bedrohungen angepasst		
9.3	Sicherheitsalarme werden regelmässig geprüft	• Werden Sicherheitsalarme regelmässig geprüft? • Sind Verantwortlichkeiten und Reaktionszeiten festgelegt?	**Zeigen lassen:** Alarmliste, Reaktionszeiten **2:** Alarme werden regelmässig von benannten Personen geprüft **3:** Reaktionszeiten festgelegt und eingehalten, auch ausserhalb der Bürozeiten (z. B. über einen Dienstleister)		
9.4	Verfahren zur Reaktion auf Sicherheitsvorfälle sind dokumentiert und einsatzbereit **[KO]**	• Ist ein Verfahren zur Reaktion auf Sicherheitsvorfälle dokumentiert und den verantwortlichen Personen bekannt? • Deckt es die wahrscheinlichsten Fälle ab (z. B. Ransomware, übernommenes E-Mail-Konto, Zahlungsbetrug)? • Ist bekannt, wer bei einem schweren Vorfall extern unterstützt (z. B. Incident-Response-Dienstleister, Hotline der Cyberversicherung)? • Wurde es getestet (z. B. mit einem Planspiel)?	**Zeigen lassen:** Plan zur Reaktion auf Sicherheitsvorfälle, Protokoll der letzten Übung **2:** Plan dokumentiert und den verantwortlichen Personen bekannt **3:** Plan wird regelmässig geübt (z. B. Planspiel) und angepasst		
9.5	Sicherheitsvorfälle werden erfasst und untersucht	• Werden Sicherheitsvorfälle erfasst und untersucht? • Werden Ursachen analysiert und Erkenntnisse (Lessons Learned) dokumentiert?	**Zeigen lassen:** Vorfallprotokoll, Beispielanalyse **2:** Vorfälle werden erfasst und untersucht **3:** Ursachen werden analysiert, Erkenntnisse führen zu Massnahmen		

9.6	Eskalations- und Meldewege, einschliesslich gesetzlicher Meldepflichten, sind festgelegt	• Sind Eskalationswege festgelegt, einschliesslich Geschäftsleitung und externer Stellen? • Sind die anwendbaren gesetzlichen Meldepflichten und Fristen bekannt (z. B. NIS2: Frühwarnung innerhalb von 24 Stunden, Meldung innerhalb von 72 Stunden, Abschlussbericht innerhalb eines Monats; ISG für kritische Infrastrukturen: Meldung von Cyberangriffen an das Bundesamt für Cybersicherheit BACS innerhalb von 24 Stunden)? • Falls Sie Produkte mit digitalen Elementen (Hardware oder Software) für den EU-Markt herstellen: Sind die Meldepflichten des EU Cyber Resilience Act bekannt (seit 11. September 2026: aktiv ausgenutzte Schwachstellen und schwerwiegende Vorfälle, Frühwarnung innerhalb von 24 Stunden, Meldung innerhalb von 72 Stunden)? • Ist festgelegt, wer an Behörden meldet und wie? • Sind die Meldepflichten bei Datenschutzverletzungen bekannt (z. B. DSG: Meldung an den EDÖB so rasch als möglich; DSGVO: innerhalb von 72 Stunden)? • Falls Sie Kunden aus dem Finanzsektor haben: Sind Fristen und Wege für Vorfallmeldungen an diese Kunden festgelegt, und können Sie sie bei der Bewältigung von Vorfällen unterstützen?	**Zeigen lassen:** Übersicht zu Eskalation und Meldungen (wer, wann, an wen) **2:** Eskalationswege, Meldepflichten und Fristen (z. B. NIS2, ISG, Datenschutz) sind bekannt, Zuständigkeiten festgelegt **3:** Meldeablauf wird geübt, Vorlagen für Meldungen liegen bereit		

Domänen-Score:

Domäne 10 – Kontinuierliche Verbesserung

Englisch: Continuous Improvement

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
10.1	Sicherheitsüberprüfungen werden periodisch durchgeführt	• Werden Sicherheitsüberprüfungen in festgelegten Abständen durchgeführt? • Werden die Ergebnisse dokumentiert?	**Zeigen lassen:** Letzte Sicherheitsüberprüfung mit Ergebnis **2:** Überprüfungen finden in festgelegten Abständen statt und sind dokumentiert **3:** Ergebnisse führen zu verfolgten Massnahmen		
10.2	Sicherheitsaudits oder -assessments werden durchgeführt	• Werden interne oder externe Sicherheitsaudits durchgeführt? • Werden die Feststellungen verfolgt?	**Zeigen lassen:** Auditbericht, Liste der Feststellungen **2:** Audits oder Assessments werden durchgeführt, Feststellungen werden erfasst **3:** Feststellungen werden bis zur Erledigung verfolgt, periodisch unabhängige Audits		
10.3	Schwachstellen werden durch regelmässige Prüfungen identifiziert, und gemeldete Schwachstellen werden behandelt	• Werden regelmässig Schwachstellenscans oder Penetrationstests durchgeführt? • Werden die Feststellungen behoben? • Gibt es einen Prozess für die Entgegennahme und Behandlung von Schwachstellenmeldungen Dritter (z. B. Sicherheitskontakt, Richtlinie zur Offenlegung von Schwachstellen)? • Falls Sie Produkte mit digitalen Elementen für den EU-Markt herstellen: Sind die Anforderungen des EU Cyber Resilience Act an die Behandlung von Schwachstellen bekannt (z. B. koordinierte Offenlegung, Sicherheitsupdates, Software-Stückliste SBOM)? • Falls Sie Kunden aus dem Finanzsektor haben: Können Sie diese bei Resilienz- und Penetrationstests unterstützen (z. B. Mitwirkung an Threat-Led Penetration Tests)?	**Zeigen lassen:** Letzter Scan- oder Penetrationstest-Bericht, Sicherheitskontakt **2:** Schwachstellenscans mindestens quartalsweise, Feststellungen werden behoben, Meldungen Dritter können entgegengenommen werden **3:** Behebungsfristen werden gemessen, regelmässige Penetrationstests, veröffentlichter Sicherheitskontakt (z. B. security.txt)		
10.4	Verbesserungsmassnahmen werden verfolgt	• Werden Verbesserungsmassnahmen mit Verantwortlichen und Terminen verfolgt? • Wird über den Fortschritt berichtet?	**Zeigen lassen:** Massnahmenliste mit Status **2:** Verbesserungsmassnahmen haben Verantwortliche und Termine **3:** Fortschritt wird regelmässig an die Geschäftsleitung berichtet		

10.5	Mitarbeitende und Geschäftsleitung erhalten Schulungen zur Sicherheitssensibilisierung	• Erhalten alle Mitarbeitenden Schulungen zur Sicherheitssensibilisierung, auch neue Mitarbeitende gleich beim Eintritt? • Erhalten die Mitglieder der Geschäftsleitung Cybersecurity-Schulungen (z. B. gemäss NIS2 Art. 20 Abs. 2)? • Werden Phishing-Simulationen durchgeführt, und wird die Teilnahme erfasst? • Behandelt die Schulung KI-gestützte Angriffe wie täuschend echte Phishing-E-Mails und Deepfakes?	**Zeigen lassen:** Schulungsnachweise inkl. Geschäftsleitung **2:** Alle Mitarbeitenden und die Geschäftsleitung werden mindestens jährlich geschult **3:** Phishing-Simulationen, rollenspezifische Schulungen (z. B. Buchhaltung, IT) und gemessene Ergebnisse		
10.6	Sicherheitskennzahlen oder KPIs werden ausgewertet	• Sind Sicherheitskennzahlen oder KPIs definiert? • Werden sie ausgewertet und berichtet?	**Zeigen lassen:** Kennzahlenübersicht **2:** Sicherheitskennzahlen sind definiert und werden ausgewertet **3:** Kennzahlen haben Zielwerte und führen zu Entscheiden		

Domänen-Score:

Domäne 11 – KI-Sicherheit (falls anwendbar; wenn anwendbar kritisch)

Englisch: AI Security

Diese Domäne ist anwendbar, sobald KI-Systeme entwickelt, betrieben oder genutzt werden, einschliesslich KI-Dienste wie KI-Assistenten oder Chat-Tools, die Mitarbeitende verwenden. Control 11.7 ist nicht anwendbar, wenn keine KI-Agenten oder KI-Integrationen mit Zugriff auf Firmendaten oder Systeme eingesetzt werden.

ID	Control	Leitfragen	Bewertungshilfe	Score	Nachweise / Notizen
11.1	KI-Systeme sind identifiziert und inventarisiert, mit festgelegten Verantwortlichen	• Sind die eingesetzten KI-Systeme und KI-Dienste identifiziert und inventarisiert? • Sind KI-Funktionen in bestehender Software (z. B. Assistenten in Office- oder CRM-Software), Browser-Erweiterungen und KI-Agenten eingeschlossen? • Hat jedes KI-System eine verantwortliche Person?	**Zeigen lassen:** KI-Inventar (inkl. von Mitarbeitenden genutzter KI-Dienste und KI-Funktionen in bestehender Software) **2:** Eingesetzte KI-Systeme und -Dienste sind inventarisiert, jedes hat eine verantwortliche Person **3:** Inventar wird bei neuen Tools nachgeführt, nicht genehmigte Nutzung wird erkannt		
11.2	KI-Sicherheitsrisiken werden bewertet	• Werden KI-spezifische Risiken bewertet (z. B. Datenabfluss, Prompt Injection, Modellmanipulation)? • Berücksichtigt die Beurteilung, dass KI über die verarbeiteten Inhalte manipuliert werden kann (z. B. E-Mails, Webseiten oder Dokumente mit versteckten Anweisungen)? • Werden regulatorische Anforderungen (z. B. EU AI Act) berücksichtigt? • Falls die Organisation eigene KI-Anwendungen entwickelt oder betreibt (z. B. einen Chatbot auf der Website): Werden diese vor dem Go-live und nach Änderungen auf KI-spezifische Angriffe getestet (z. B. anhand der OWASP Top 10 for LLM Applications)?	**Zeigen lassen:** KI-Risikobeurteilung, Testergebnisse eigener KI-Anwendungen **2:** KI-spezifische Risiken (z. B. Datenabfluss, Prompt Injection) sind beurteilt, regulatorische Anforderungen berücksichtigt, eigene KI-Anwendungen werden vor dem Go-live getestet **3:** Beurteilung wird bei neuen Anwendungsfällen und Änderungen wiederholt, eigene KI-Anwendungen werden nach Änderungen erneut getestet		
11.3	Richtlinien zur KI-Nutzung und Sicherheitsmassnahmen sind festgelegt und umgesetzt	• Sind Richtlinien zur KI-Nutzung festgelegt und kommuniziert? • Sind technische Schutzmassnahmen (Guardrails) und Zugriffskontrollen für KI-Systeme umgesetzt? • Werden die Zugriffsrechte auf Firmendaten geprüft und bereinigt, bevor KI-Assistenten mit Zugriff auf diese Daten eingeführt werden? • Werden die Mitarbeitenden im sicheren Umgang mit KI-Tools geschult (in der EU verlangt auch Art. 4 EU AI Act Massnahmen zur Förderung der KI-Kompetenz)?	**Zeigen lassen:** Richtlinie zur KI-Nutzung, Einstellungen zu Guardrails und Zugriffen, Schulungsnachweise **2:** Richtlinie legt erlaubte Tools und Daten fest, Zugriffe sind geregelt, Mitarbeitende sind geschult **3:** Technische Schutzmassnahmen (z. B. Data Loss Prevention, eingeschränkte Konnektoren) setzen die Richtlinie durch, Zugriffsrechte werden vor der Einführung von KI-Assistenten geprüft		

11.4	KI-Systeme werden auf Sicherheitsereignisse und unerwartetes Verhalten überwacht	• Werden KI-Systeme auf Sicherheitsereignisse überwacht? • Wird unerwartetes Verhalten erkannt und geprüft? • Zeigen die Protokolle, wer welches KI-System genutzt hat und, soweit rechtlich zulässig, welche Ein- und Ausgaben verarbeitet wurden? • Sind Limiten für Nutzung und Kosten festgelegt, damit Missbrauch und unerwarteter Verbrauch auffallen?	**Zeigen lassen:** KI-Monitoring oder Audit-Logs **2:** Nutzung und Sicherheitsereignisse von KI-Systemen werden protokolliert und überwacht **3:** Unerwartetes Verhalten wird systematisch erkannt und ausgewertet		
11.5	KI-Sicherheitsvorfälle werden untersucht	• Werden KI-bezogene Sicherheitsvorfälle erfasst und untersucht? • Deckt der Vorfallprozess KI-spezifische Fälle ab (z. B. vertrauliche Daten in ein KI-Tool eingegeben, manipulierter KI-Agent)?	**Zeigen lassen:** Vorfallprotokolle mit KI-Bezug **2:** KI-Vorfälle sind Teil des Vorfallprozesses **3:** Erkenntnisse führen zu Anpassungen von KI-Richtlinien und -Massnahmen		
11.6	KI-Sicherheit ist Teil des Reportings an die Geschäftsleitung und der kontinuierlichen Verbesserung	• Ist KI-Sicherheit Teil des Reportings an die Geschäftsleitung? • Ist KI-Sicherheit Teil der Aktivitäten zur kontinuierlichen Verbesserung?	**Zeigen lassen:** Bericht an die Geschäftsleitung mit KI-Teil **2:** KI-Sicherheit ist Teil des Reportings an die Geschäftsleitung **3:** KI-Sicherheit hat eigene Ziele und Kennzahlen in der kontinuierlichen Verbesserung		
11.7	KI-Agenten und KI-Integrationen haben nur die Zugriffsrechte, die sie benötigen, und kritische Aktionen erfordern eine menschliche Freigabe	• Werden überhaupt KI-Agenten oder KI-Integrationen mit Zugriff auf Firmendaten oder Systeme eingesetzt? Falls nicht, ist dieses Control nicht anwendbar (N/A). • Welche Aktionen können KI-Agenten, KI-Assistenten oder Integrationen selbständig ausführen (z. B. E-Mails senden, Dateien ändern, Zahlungen auslösen)? • Nutzen sie eigene Konten mit eingeschränkten, aufgabenbezogenen Rechten statt Administrator- oder persönlicher Konten mit weitreichendem Zugriff? • Erfordern kritische Aktionen (z. B. Zahlungen, Massenmails, Löschen von Daten, Änderungen an Systemen) eine menschliche Freigabe? • Sind Freigaben auf wirklich kritische Aktionen beschränkt, damit sie sorgfältig geprüft und nicht aus Gewohnheit bestätigt werden? • Werden nur genehmigte Konnektoren, Plugins und Erweiterungen verwendet, und kann ein Agent rasch gestoppt werden?	**Zeigen lassen:** Übersicht der KI-Agenten und Integrationen mit ihren Rechten, Einstellungen zur Freigabe **2:** Rechte sind auf die Aufgabe beschränkt, kritische Aktionen erfordern eine Freigabe, nur genehmigte Konnektoren werden verwendet **3:** Rechte werden regelmässig überprüft, Aktionen der Agenten werden protokolliert, Agenten können sofort gestoppt werden		

11.8	KI-Dienste und KI-Anbieter werden vor der Nutzung beurteilt	• Wird vor der Nutzung geprüft, ob der Anbieter eingegebene Daten zum Training verwendet, wo und wie lange die Daten gespeichert werden und wer darauf zugreifen kann? • Werden für Firmendaten Business-Versionen mit vertraglichem Datenschutz statt kostenloser Privatversionen verwendet? • Werden Zertifizierungen oder Testate des Anbieters berücksichtigt (z. B. ISO/IEC 27001, ISO/IEC 42001, BSI C5 oder AIC4)? • Falls KI-Modelle heruntergeladen und lokal betrieben werden (z. B. frei verfügbare Open-Weight-Modelle): Werden sie nur aus vertrauenswürdigen Quellen bezogen und vor der Nutzung freigegeben?	**Zeigen lassen:** Beurteilung des Anbieters, Vertrag oder Nutzungsbedingungen, Auftragsverarbeitungsvertrag, Liste der freigegebenen KI-Dienste und Modelle **2:** KI-Dienste werden erst nach Prüfung von Datennutzung, Speicherort und Vertrag freigegeben; lokal betriebene Modelle stammen aus vertrauenswürdigen Quellen **3:** Anbieter werden periodisch und bei geänderten Bedingungen erneut beurteilt		
11.9	KI-generierte Ergebnisse werden von Menschen geprüft, bevor sie für wichtige Entscheidungen verwendet, veröffentlicht oder produktiv eingesetzt werden	• Ist festgelegt, welche KI-Ergebnisse von einer Person geprüft werden müssen (z. B. Verträge, Kundenkommunikation, veröffentlichte Inhalte, Programmcode, Entscheidungen über Personen)? • Ist klar, dass die Verantwortung für ein Ergebnis bei der Person bleibt, die es verwendet? • Wird KI-generierter Programmcode vor dem Einsatz wie anderer Code geprüft und getestet?	**Zeigen lassen:** Regeln zur Prüfung von KI-Ergebnissen, Beispiele durchgeführter Prüfungen **2:** Prüfpflichten sind festgelegt und bekannt, die Verantwortung ist klar **3:** Einhaltung wird stichprobenweise geprüft, gefundene Fehler führen zu Anpassungen der Regeln		

Domänen-Score:

Ergebnisübersicht

Domäne	Kritisch	Score
1. Unternehmens- und Sicherheits-Governance	Ja	
2. Risikomanagement		
3. Sicherheitsrichtlinien und -prozesse		
4. Identitäts- und Zugriffsmanagement	Ja	
5. Infrastruktursicherheit		
6. Endgerätesicherheit		
7. Netzwerksicherheit		
8. Datensicherheit, Backup und Wiederherstellung	Ja	
9. Monitoring und Vorfallbehandlung	Ja	
10. Kontinuierliche Verbesserung		
11. KI-Sicherheit (falls anwendbar)	Ja	

ACP-Gesamtscore:

ACP-Reifegrad:

Knock-out-Control mit Score 0: □ Nein □ Ja (ID:)